HARDCODED SECRETS & ENVIRONMENT CONFIGURATION AUDIT

Comprehensive Full-Stack Audit: Missing .env Analysis, Hardcoded Credentials & Architecture Roadmap

SCOPE	ENVIRONMENT STATE	AUDIT MODE	AUDIT TIMESTAMP
EFV-F-main (Frontend + Next.js Server Route)	.env Missing / Unconfigured	Strict READ-ONLY	November 3, 2026

AUDIT FINDING: DANGEROUS FALLBACK ANTI-PATTERN DETECTED

In the absence of a configured `.env` file, developers hardcoded production administrator passwords, live master authentication API keys, Google Cloud Run endpoints, and Google OAuth Client IDs directly into JavaScript/TypeScript source files and build configurations.

3	4	4	0
P0 CRITICAL SECRETS	P1 HIGH SECRETS	P2 CONFIG EXPOSURE	DB STRINGS IN REPO

1. EXECUTIVE SUMMARY

This audit investigated why and where confidential values exist in the codebase in the absence of an active `.env` file. Next.js was architected to read dynamic configurations via `src/app/api/config.js/route.ts` (which prints a runtime warning: `"Both NEXT_PUBLIC_API_URL and efv_backend_api are missing in .env!"`). Because no `.env` was supplied during local development and builds, developers bypassed environment abstraction and hardcoded production credentials, master API keys, and internal endpoints directly into code.

2. HARDCODED SECRET FINDINGS (FINDING CARDS)

SEC-ENV-01: Plaintext Admin Account Credentials & Auth Bypass Check

P0 CRITICAL

File: `public/js/cart.js:2731` **Domain:** Frontend Static Script **Category:** Admin Passwords **Git Status:** Untracked (Will Push)

Masked Evidence: `if (email === 'admin@uwo24.com' && (password === 'efv@2***' || password === 'efv@1***')) { fetch(`${API_BASE}/api/auth/login`) ... }`

Impact: Exposes the production administrative credentials. An attacker reading the repository or browser bundle can authenticate as administrator and obtain an admin JWT.

Remediation: Delete lines 2730–2736 from `cart.js`. Never store or check administrator passwords in frontend code. Rotate password on production database immediately.

SEC-ENV-02: Master Live Unified-Auth API Key

P0 CRITICAL

Files: `UWOLoginModal.tsx:23`, `LibraryDashboard.tsx:114`, `dashboard/page.tsx:73`, `cart.js:3045` **Domain:** Frontend Components **Category:** Master API Key **Git Status:** Untracked (Will Push)

Masked Evidence: `apiKey = 'key_efv_live_master_2***'` • Transmitted in HTTP header `X-Application-Key: API_KEY` to `https://uwo24.com/api/unified-auth/*`.

Impact: Gives arbitrary client browsers programmatic authorization to register users, reset passwords, and provision sessions against the central UWO24 authentication service.

Remediation: Remove `key_efv_live_master_*` from frontend. Create a Next.js server-side proxy route and inject `UWO_MASTER_API_KEY` from a private server-side environment variable. Rotate the key in the database immediately.

SEC-ENV-03: Confidential Business IP & Architecture Roadmap in Public Script

P0 CRITICAL

File: `public/js/efv-pdf-data.js:1` **Domain:** Frontend Public Asset **Category:** Trade Secrets / IP **Git Status:** Untracked (Will Push)

Evidence: 201 KB Base64 PDF containing *"EFV Framework - App & Tech Work Checklist"* detailing tokenomics (EFV Coin), watch hardware sensors (EFV Watch), database schemas, and patent strategies. Loaded across 5 HTML pages.
Impact: Irreversible public leakage of corporate trade secrets and unpublished intellectual property.

Remediation: Delete `public/js/efv-pdf-data.js` and remove the 5 `<script src="../js/efv-pdf-data.js">` tags.

SEC-ENV-04: Hardcoded Production Cloud Run URLs & GCP Project IDs

P1 HIGH

Files: `api-config.js`, `api-config.bak.js`, `cloudbuild.yaml`, `api.ts`, `AuthContext.tsx` **Domain:** Frontend / DevOps **Category:** Infrastructure URL **Git Status:** Untracked (Will Push)

Masked Evidence: `https://efv-b-246449377***.asia-south1.run.app` & `https://efvbackend-743928421***.asia-south1.run.app`.
Impact: Exposes microservice hostnames and Google Cloud Project numbers (246449377479, 743928421487), bypassing custom domain WAFs and enabling direct layer-7 DDoS.

Remediation: Delete `api-config.bak.js`. Inject `NEXT_PUBLIC_API_URL` via environment variables. Map backend to a custom domain (e.g. `api.efvframework.com`).

SEC-ENV-05: Hardcoded Google OAuth 2.0 Client IDs

P1 HIGH

Files: `cloudbuild.yaml:9`, `public/js/api-config.js:9`, `public/js/cart.js:3586` **Domain:** Frontend / CI/CD **Category:** OAuth Client ID **Git Status:** Untracked (Will Push)

Masked Evidence: `743928421***-tgh59ajhsmuk5ltomsooj46lials3hpt.apps.googleusercontent.com` & `246449377***-favi4q5sskhc1hnljs53aik69ftnr6bf.apps.googleusercontent.com`.
Impact: Hardcoded across build files. If authorized redirect URIs in Google Cloud Console are misconfigured, permits OAuth origin phishing.

Remediation: Supply via `NEXT_PUBLIC_GOOGLE_CLIENT_ID` environment variable. Lock authorized JavaScript origins in Google Cloud Console.

SEC-ENV-06: Local Workstation Memory Dumps & Diagnostics in tool/

P1 HIGH

Files: `tool/lint_output.txt` (493KB), `tool/build_log.txt`, `tool/lint_out.json` **Domain:** Build Diagnostics **Category:** System Paths / AST Dump **Git Status:** Untracked (Will Push)

Evidence: 500KB+ diagnostic dumps containing local Windows paths and developer usernames.
Impact: System reconnaissance leakage; discloses local directory topology and internal compilation errors.

Remediation: Delete the `tool/` folder or add `tool/` to `.gitignore`.

3. FRONTEND VS. BACKEND ENVIRONMENT BOUNDARY AUDIT

Inspection Category	Frontend Findings (Client Bundle Risk)	Backend / Next.js Server Findings
Credentials & Passwords	Plaintext admin passwords in `public/js/cart.js:2731` (`efv@2026` / `efv@1234`). Accessible to all web visitors.	None. Server-side Next.js route has no hardcoded passwords.
API Keys & Master Secrets	Master API key `key_efv_live_master_2026` in `UWOLoginModal.tsx`, `LibraryDashboard.tsx`, `cart.js`. Transmitted in client headers.	Server-side route `src/app/api/config.js/route.ts` is designed to receive env vars, but none were configured in `.env`.
Database Information	No database credentials found. Connects via external REST endpoints.	Zero database connection strings (MongoDB/PostgreSQL/Redis) exist in this repository.
Infrastructure Endpoints	Hardcoded Cloud Run endpoints in `api-config.js`, `cart.js`, `api.ts`, `AuthContext.tsx`.	`cloudbuild.yaml` hardcodes deployment image tags and Cloud Run service names (`aisa-frontend`).
JSON Configuration Files	12 localization JSONs (`public/locales/*.json`) verified safe (UI dictionaries). `public/package-lock.json` is stray clutter.	`tool/lint_out.json` & `tool/lint_out_utf8.json` contain developer workstation paths and source code excerpts.

4. COMPLETE ENVIRONMENT VARIABLE ARCHITECTURE

To replace all hardcoded values cleanly and securely, the project architecture should implement the following split between **Server-Side Private Environment Variables** and **Client-Side Public Variables**:

A. Recommended `.env.example` (Safe to commit to Git as a template)

```
# ================================================================================
# EFV PROJECT ENVIRONMENT CONFIGURATION TEMPLATE (.env.example)
# DO NOT STORE ACTUAL PRODUCTION PASSWORDS OR SECRETS IN THIS TEMPLATE FILE.
# ================================================================================

# --- [BACKEND / SERVER-SIDE ONLY - NEVER EXPOSE TO CLIENT] ---
PORT=8080
HOSTNAME="0.0.0.0"

# Central Unified Auth Master Secret (Used by Next.js Server Proxy Routes)
UWO_MASTER_API_KEY=your_private_uwo_master_key_here

# Central Unified Auth Server URL
UWO_AUTH_API_URL=https://uwo24.com/api

# Internal Backend Microservice URL (Direct server-to-server calls)
BACKEND_INTERNAL_API_URL=https://api.efvframework.com

# --- [FRONTEND / CLIENT-FACING - PREFIXED WITH NEXT_PUBLIC_] ---
# Public API Gateway (Must be a custom branded domain behind WAF, not raw Cloud Run)
NEXT_PUBLIC_API_URL=https://api.efvframework.com
```

```
# Unified Auth Public Base URL
NEXT_PUBLIC_UNIFIED_API_URL=https://uwo24.com/api

# Google OAuth 2.0 Web Client ID (Public Identifier)
NEXT_PUBLIC_GOOGLE_CLIENT_ID=your_google_oauth_client_id.apps.googleusercontent.com

# Analytics & Monitoring Identifiers (Public by design)
NEXT_PUBLIC_GA4_MEASUREMENT_ID=G-D2Z48EXJ9Z
NEXT_PUBLIC_META_PIXEL_ID=1015594134713138
NEXT_PUBLIC_CLARITY_PROJECT_ID=xna8nwpoq6
```

B. Mapping Hardcoded Values to Target Environment Variables

Hardcoded Value in Code	Current File Location	Target Environment Variable	Exposure Scope
`https://efv-b-246449377479.asia-south1.run.app`	`api.ts`, `AuthContext.tsx`, `api-config.js`	`NEXT_PUBLIC_API_URL`	Frontend Public
`key_efv_live_master_2026`	`UWOLoginModal.tsx`, `cart.js`	`UWO_MASTER_API_KEY`	**Backend Private Only**
`246449377479-favi4q5sskhc1hnljs53aik...`	`api-config.js`, `cart.js`	`NEXT_PUBLIC_GOOGLE_CLIENT_ID`	Frontend Public
`https://uwo24.com/api`	`cart.js:3044`, `UWOLoginModal.tsx:48`	`NEXT_PUBLIC_UNIFIED_API_URL`	Frontend Public
`G-D2Z48EXJ9Z`	`inject-ga4.js`, `layout.tsx`	`NEXT_PUBLIC_GA4_MEASUREMENT_ID`	Frontend Public
`1015594134713138`	`inject-pixel.js`, `layout.tsx`	`NEXT_PUBLIC_META_PIXEL_ID`	Frontend Public
`xna8nwpoq6`	`inject-clarity.js`, `layout.tsx`	`NEXT_PUBLIC_CLARITY_PROJECT_ID`	Frontend Public
`efv@2026` / `efv@1234`	`public/js/cart.js:2731`	**DELETE FROM CODE ENTIRELY**	**Database Password Hash Only**

5. EXPLICIT ANSWERS TO YOUR 8 AUDIT QUESTIONS

1. Does the project contain hardcoded credentials?
YES. Plaintext administrator passwords (`efv@2026` and `efv@1234`) are hardcoded in `public/js/cart.js:2731`, and a live master application API key (`key_efv_live_master_2026`) is hardcoded across four separate files.

2. Which credentials should be moved to environment variables?
The master API key (`key_efv_live_master_2026`) must be moved to a **private server-side environment variable** (`UWO_MASTER_API_KEY`). The administrator passwords must **NOT** be in environment variables or code; they must be removed entirely and validated solely on the backend database via bcrypt/Argon2 password hashing.

3. Are any private secrets exposed in frontend code?
YES. Both the plaintext admin password and the live master API key are exposed directly in client-side frontend code and are sent over client HTTP request headers. Additionally, a confidential 201 KB business architecture PDF is exposed in base64 in `public/js/efv-pdf-data.js`.

4. Are any production credentials present in backend code?
In `cloudbuild.yaml`, production Cloud Run endpoints and Google OAuth Client IDs are hardcoded in container build arguments (`VITE_GOOGLE_CLIENT_ID` and `NEXT_PUBLIC_API_URL`) instead of using Cloud Build substitution variables or Google Secret Manager.

5. Have any credentials already been committed or pushed to GitHub?
Locally: NO. The local directory has no active `.git` repository, so zero secrets have been committed locally. **Remotely:** If earlier versions of this project were pushed to `github.com/EFV-Official/EFV-Website`, those remote commits must be audited on GitHub immediately.

6. Which credentials require immediate rotation?
1. **Admin Account Password:** Change the password for `admin@uwo24.com` on the production database immediately.
2. **Master API Key:** Revoke `key_efv_live_master_2026` in the central UWO24 database and re-issue a new key.

7. What environment variables are required for this project's actual architecture?
For this project architecture, 7 environment variables are required: `UWO_MASTER_API_KEY` (backend private), `UWO_AUTH_API_URL`, `NEXT_PUBLIC_API_URL`, `NEXT_PUBLIC_UNIFIED_API_URL`, `NEXT_PUBLIC_GOOGLE_CLIENT_ID`, `NEXT_PUBLIC_GA4_MEASUREMENT_ID`, and `NEXT_PUBLIC_META_PIXEL_ID`.

8. Is the project safe to push to GitHub?
NO. THE PROJECT IS STRICTLY NOT SAFE TO PUSH TO GITHUB. Pushing now will publish production admin passwords, live authentication keys, and proprietary corporate trade secrets.

6. PRIORITIZED REMEDIATION CHECKLIST

- **P0:** Delete lines 2730–2736 from `public/js/cart.js` to remove admin passwords. Rotate password on production database.
- **P0:** Remove `key_efv_live_master_2026` from `UWOLoginModal.tsx`, `LibraryDashboard.tsx`, `dashboard/page.tsx`, and `cart.js`. Rotate in UWO database.
- **P0:** Delete `public/js/efv-pdf-data.js` and remove the 5 script tags from HTML pages.
- **P1:** Delete `public/js/api-config.bak.js`, `public/package-lock.json`, `public/js/grep_location.txt`, and the `tool/` folder.
- **P2:** Delete duplicate images (`* - Copy.*`) and offload `EFV(VIDEO).mp4` to cloud storage.
- **P2:** Create `.env.example` and update `.gitignore` with comprehensive exclusion rules.